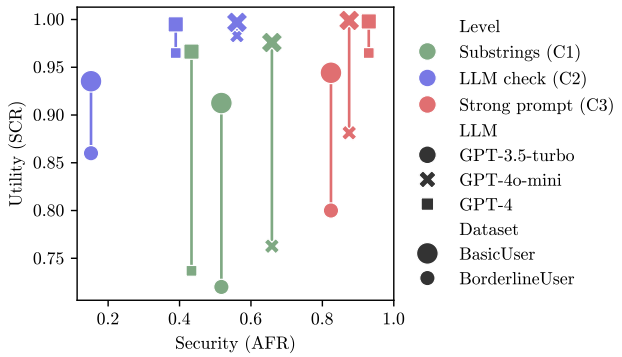


Figure 3: *The choice of benign data strongly impacts user utility, highlighting the importance of selecting application-relevant data when maximizing developer utility.* Across defenses, utility can change substantially depending on whether `BasicUser` or `BorderlineUser` is used. Colors represent the defense, shapes the underlying LLM, and size the benign data source.

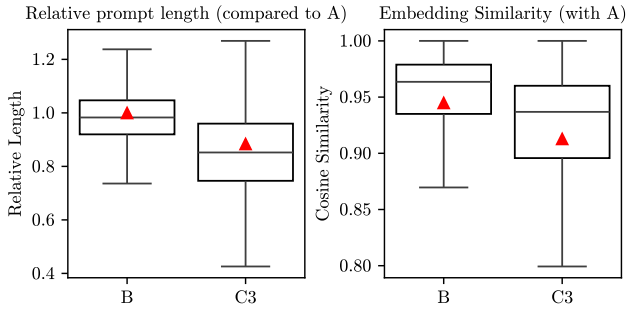


Figure 4: *System prompt defenses degrade utility beyond simple request blocking.* There is a noticeable impact of system prompt defenses on output quality, reflected in reduced response length (left) and altered content similarity (right). This suggests that even when user requests are not blocked, defenses can still degrade utility. Triangles denote the mean, the box the 25%, 50% and 75% quantiles, respectively, and the whiskers the minimum and maximum values.

all C levels and LLMs. We use AFR with `Gandalf-RCT` to measure security and SCR with both `BasicUser` and `BorderlineUser` (taking user sessions to have length one) to measure utility, see Section 2.3.

The resulting security and utility estimates for each defense (level-LLM combination) and for varying benign user data (`BasicUser` and `BorderlineUser`) are shown in Figure 3. For most defenses, there are large differences between the utility on `BasicUser` and `BorderlineUser`, demonstrating the importance of choosing realistic user data when estimating utility (e.g., messages sent to an IT support bot might lead to a more borderline distribution than that given by `BasicUser`). Our choice of user data is somewhat arbitrary as we are not considering an actual application, however in practice, the user pool is generally well defined and it is easy to collect representative user data.

As noted in Section 2, SCR captures utility loss only from blocked requests. However, defenses integrated into the LLM, such as system prompt defenses, can affect application behavior without blocking. To illustrate this, we compare an undefended LLM (level A), expected to maximize utility, with system prompt-defended variants (levels B and C3). Using response character length and cosine similarity as proxies for utility, Figure 4 shows that strong defenses significantly reduce response length and alter content, suggesting degraded response quality. Even weaker defenses (level B) show smaller but measurable reductions. These results emphasize that system prompt defenses while enhancing security can subtly impact utility by changing model behavior beyond simple request blocking.

We stress that we did not optimize defenses equally. For example, more work went into setting up the strong system prompt than the LLM checker. Thus, these results should not be used to draw general conclusions about the relative security of the different types of defenses (system prompt, LLM checker, and substring checks). Such comparisons are generally difficult and depend strongly on the setup.

### 4.2. Defense Strategies in D-SEC

D-SEC emphasizes the importance of selecting defenses based on the security-utility trade-off. We now empirically evaluate the defense strategies discussed in Section 2.4 and show how, in practice, defenses can be selected to maximize a preselected developer utility.

**Restricted Application Domain** By looking at how difficult it is to generate exploits in the three setups (general, topic, and summarization), we can assess how restricting the application to a narrower task impacts security. Here, we restrict the application via the system prompt, but this can also be achieved by using specialized LLMs or fine-tuning the LLM on task-specific data. Table 1 suggests that level difficulty, measured as the average number of levels solved by a player on each setup, increases for the narrower summarization and topic tasks. We see this as encouraging evidence that, if possible, using LLMs in more targeted application domains is a powerful approach to increasing security. In practice, one should also ensure that utility is not negatively impacted by restricting the application domain.

**Defense-in-Depth** `Gandalf-RCT` shows that level D, which combines all level C defenses with an 'or' aggregation, is the most challenging level, see Appendix D. Although all players who played level D were able to solve all C levels, the percentage of players able to beat level D

Table 1: *Average levels solved per session.* Summarization is the most difficult setup, followed by topic, suggesting that a more restricted use case can improve defenses.

| | GPT-3.5-turbo | GPT-4o-mini | GPT-4 |
|---|---|---|---|
| General | 1.95 | 1.50 | 1.73 |
| Summarization | 1.27 | 1.01 | 1.28 |
| Topic | 1.81 | 1.12 | 1.37 |

among all that played was 2.9%, 6.3%, and 6.4% for the setups general, summarization, and topic, respectively. While this shows that the 'or' aggregation substantially increases security, it may have a strong negative impact on utility.

As discussed in Section 2.4, the security-utility trade-off of a defense-in-depth aggregation depends on the relation between the defenses. To investigate this, we need to evaluate each individual defense on the exact same attack and user transactions. For `Gandalf-RCT` this is not directly available because each player only submitted each of their attacks once. We, therefore, conduct a semi-synthetic experiment in which we resubmit the last prompts from each session to all C-levels. We use `BorderlineUser` as user data. All details on the data processing are provided in Appendix E.1.

We now visualize which defenses block which attacks using a Venn diagram in Figure 5. It can be seen that only 14.5% of the attacks are blocked by all defenses, indicating that the defenses are catching different attacks and combining multiple defenses can increase security. To find the optimal aggregation $f^*$ defined in (9), we use an exhaustive search to maximize developer utility $V^{\lambda}_{\mathcal{D}_f}$ over all $f$. $V^{\lambda}_{\mathcal{D}_f}$ for the 'or'-, 'and'- and $f^*$-aggregations for different trade-off parameters $\lambda$ are given Table S.10 in . Depending on the value of $\lambda$, the optimal aggregation is non-trivial and lies somewhere between an 'or' and an 'and' aggregation. More details are provided in Appendix F.1.

**Adaptive Defenses** Even the most secure defense in level $D$ is beaten by some attackers. As we show here, we can substantially strengthen our defenses by making them adaptive, i.e., allowing them to take the session's structure into account. We focus on the most basic class of adaptive defenses, which limits the number of times a defense flags a potential attack (i.e., blocks a transaction) before blocking the entire session, such that the attacker can no longer submit prompts. Other adaptive strategies could incorporate the session history in subtler ways.

To simplify the analysis, we focus only on the undetected attacks from the 'or'-aggregation in Section 2.4, as these can be considered the hardest attacks to detect. As we are considering adaptive defenses, we also want to assume that

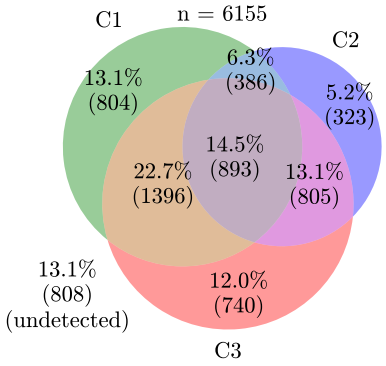


Figure 5: *A defense-in-depth strategy is effective in increasing security.* A fraction of attacks are caught exclusively by one of the defenses (C1, C2, and C3), so their combination outperforms all individual defenses.

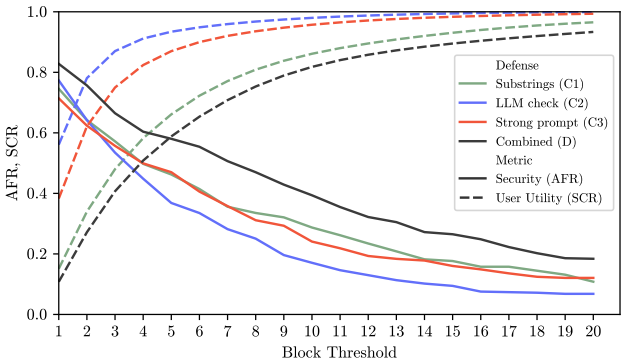


Figure 6: *Adaptive defenses that block attempts past a block threshold enhance security.* In practice, the block threshold can be selected to strike the right security-utility trade-off.

user sessions consist of multiple transactions. We resample user transactions to create user sessions with the same session length distribution as in `Gandalf-RCT` for each level separately, see Appendix E.2 for details.

The estimated AFR and SCR with `BorderlineUser` for adaptive defenses with varying block threshold $T$ based on each of the defenses in levels C1, C2, C3, and D (averaged over the LLMs) is shown in Figure 6. This shows that adaptive defenses with a low block threshold are able to significantly increase security over non-adaptive defenses that block individual transactions only. For instance, using a block threshold of 3 with the combined defense is able to block 75% of the attacks that were not caught by any of the non-adaptive attacks. The added security comes at the cost of utility, hence, in practice, we recommend to select the block threshold such that it maximizes developer utility. More detailed results are provided in Appendix F.2.

## 5. Discussion

Our analysis highlights that LLM security demands a shift from static to dynamic threat models that account for utility: Real-world attacks are adversarial, underscoring the need to evaluate defenses accordingly. Unlike traditional security layers, defenses in LLM applications are more integrated and, hence, implicitly affect usability. These challenges are only amplified in emerging agentic systems, which operate autonomously in dynamic environments while interacting with external tools. Attackers can exploit this openness to manipulate agents, misuse tools, or disrupt workflows. Effective defenses must manage this interdependence between security, execution flow, and usability.

D-SEC provides a foundation for tackling these challenges, but important limitations remain. First, data collection to optimize defenses within D-SEC is inherently difficult. While Gandalf demonstrates the potential of crowd-sourced red-teaming, its narrow scope limits scalability and generalizability to diverse LLM applications. Automated red-teaming solutions that can rival Gandalf in diversity and accuracy are needed. Second, comparing defense mechanisms remains a challenge, as ensuring equal restrictiveness across different approaches is difficult and can skew conclusions. Third, new adaptive defenses (beyond time-based blocking) must be developed, especially in agentic systems where historical context and nuanced interactions are pivotal. Lastly, utility metrics must expand beyond blocking alone to capture the full spectrum of user experience impacts, particularly in agentic systems.

While the insights from Gandalf provide valuable foundations, they are limited by the narrow application domain of password extraction, necessitating broader empirical analysis to draw application-agnostic conclusions. Although our experiments utilize Gandalf in a controlled experimental setting, the D-SEC framework is explicitly designed for real-world deployment. Practitioners can implement the core strategies: domain restriction, defense aggregation, and adaptive defenses.

The ultimate validation of D-SEC lies in its successful adoption and its application across diverse use cases, establishing it as a comprehensive framework to guide the next generation of secure and usable LLM applications.

## Acknowledgments

We would like to thank Niki Kilbertus for his insightful review of this paper. AT worked at RSA Conference while writing the paper.

## Impact Statement

This paper addresses the critical challenge of evaluating the security of LLM applications, identifying key limitations in existing methodologies and proposing a comprehensive framework to guide future research. By open-sourcing our dataset, we aim to foster transparency, reproducibility, and collaboration within the research community, enabling deeper insights into LLM security. Our work underscores a commitment to responsible AI development, ensuring that LLM applications are not only secure but also contribute positively to society by mitigating potential risks and fostering trust in AI-driven technologies.

While we believe that openness ultimately leads to better security outcomes by enabling the community to learn from and address vulnerabilities, we have proactively included a responsible use license in our datasets to promote ethical research and prevent misuse. The license explicitly prohibits offensive security activities without prior consent from system owners, reinforcing our commitment to responsible AI development.

## References

Ayub, M. A. and Majumdar, S. Embedding-based classifiers can detect prompt injection attacks. *arXiv preprint arXiv:2410.22284*, 2024.

Bai, Y., Kadavath, S., Kundu, S., Askell, A., Kernion, J., Jones, A., Chen, A., Goldie, A., Mirhoseini, A., McKinnon, C., Chen, C., Olsson, C., Olah, C., Hernandez, D., Drain, D., Ganguli, D., Li, D., Tran-Johnson, E., Perez, E., Kerr, J., Mueller, J., Ladish, J., Landau, J., Ndousse, K., Lukosuite, K., Lovitt, L., Sellitto, M., Elhage, N., Schiefer, N., Mercado, N., DasSarma, N., Lasenby, R., Larson, R., Ringer, S., Johnston, S., Kravec, S., El Showk, S., Fort, S., Lanham, T., Telleen-Lawton, T., Conerly, T., Henighan, T., Hume, T., Bowman, S. R., Hatfield-Dodds, Z., Mann, B., Amodei, D., Joseph, N., McCandlish, S., Brown, T., and Kaplan, J. Constitutional AI: Harmlessness from AI feedback. *arXiv preprint arXiv:2212.08073*, 2022.

Brown, T., Mann, B., Ryder, N., Subbiah, M., Kaplan, J. D., Dhariwal, P., Neelakantan, A., Shyam, P., Sastry, G., Askell, A., Agarwal, S., Herbert-Voss, A., Krueger, G., Henighan, T., Child, R., Ramesh, A., Ziegler, D., Wu, J., Winter, C., Hesse, C., Chen, M., Sigler, E., Litwin, M., Gray, S., Chess, B., Clark, J., Berner, C., McCandlish, S., Radford, A., Sutskever, I., and Amodei, D. Language models are few-shot learners. In Larochelle, H., Ranzato, M., Hadsell, R., Balcan, M., and Lin, H. (eds.), *Advances in Neural Information Processing Systems*, volume 33, pp. 1877–1901. Curran Associates, Inc., 2020.